UNIVERSIDAD DE LA SABANA · ARQUITECTURA EMPRESARIAL (AREM)

Arquitectura Empresarial TO-BE y Gobernanza para Insuclínicos Ltda.

Simulación de Comité de Arquitectura (Taller 9): Defensa de la transición desde Excel aislado y papel en planta hacia una plataforma Cloud unificada con trazabilidad sanitaria INVIMA.

Cliente Real: Insuclínicos Ltda. (Bogotá) · Rep. Legal: Santiago Martínez · 6 trabajadores · ~40 clínicas

Grupo 8 (50/50): Jorge Steven Doncel (@gevengood) [Actos 1 y 3] · David Santiago Buendía (@Santiagoob7) [Actos 2 y 4]

Evidencia Consolidada: Talleres 0 a 9 · Repositorio técnico + 2 vistas ArchiMate + Matriz 7 Dominios

Sustentación Final · Tiempo objetivo: 10 minutos (4 Actos + Cierre)

RESUMEN EJECUTIVO DE LA PROPUESTA

INVERSIÓN ANUAL

~$2.2M COP

Dentro del tope <= $3.0M COP/año (Odoo/Dolibarr)

HORIZONTE DE CAMBIO

12 Semanas

4 Work Packages graduales sin parar producción

SALTO NORMATIVO

13.3% → 100%

De 2/15 controles a trazabilidad INVIMA + Ley 1581

RIESGOS CONSOLIDADOS

10 Riesgos

7 dominios · 4 críticos mitigados · R10 aceptado

Contexto de Insuclínicos Ltda. y Restricciones de Negocio

ACTO 1 · PROBLEMA

PyME manufacturera de ropa quirúrgica SMS en Bogotá con alta presión regulatoria y presupuesto acotado (Taller 0)

6 Trabajadores

Operación multifuncional entre ventas, confección, almacén y despacho.

~40 Clínicas y Spas

Base B2B recurrente en salud que exige remisiones claras y respuesta rápida.

Tela Quirúrgica SMS

Insumo crítico por rollo/lote sujeto a regulación sanitaria INVIMA.

<= $3.0M COP/año

Techo anual estricto: exige reusar PCs actuales y cero desarrollo costoso.

Restricciones Innegociables del Cliente (Taller 0)

Continuidad física: Transición gradual sin detener un solo día la planta ni los despachos.

Reúso tecnológico: Aprovechar computadores Windows existentes y conectividad PyME.

Simplicidad operativa: Sin equipo de TI interno; herramientas intuitivas de curva corta.

Objetivos Estratégicos y Necesidad de Negocio (Ficha Taller 0)

OE-01 · Aumentar Capacidad y Eficiencia de Producción

Eliminar tiempos muertos pasando órdenes verbales/impresas en papel hacia confección y reducir re-digitaciones administrativas (~6 h/semana perdidas).

OE-02 · Control en Tiempo Real de Inventarios y Tela SMS

Suprimir la brecha entre stock registrado y consumo real en planta por rollo/bata/polaina, evitando bloqueos diarios y compras de urgencia.

OE-03 · Digitalización de Punta a Punta y Trazabilidad INVIMA

Vincular pedido → lote de rollo SMS → orden de confección → remisión clínica y exportación ágil hacia facturación electrónica DIAN.

Por qué es Urgente Cambiar: Operación Desconectada y Ciega

ACTO 1 · PROBLEMA

Flujo fragmentado entre WhatsApp, dos Excel en red local y órdenes en papel (Evidencia: BPMN Taller 1 & ER/Contexto Taller 2)

FLUJO OPERATIVO AS-IS IDENTIFICADO EN BPMN (TALLER 1) Y PUNTOS DE QUIEBRE DE INFORMACIÓN (TALLER 2)



Dos Silos Excel en Carpeta LAN

2–3 Bloqueos / Día

Ventas e Inventario viven en libros separados sin integridad referencial. Cuando dos áreas editan a la vez, Excel bloquea en solo-lectura o crea copias conflictivas.

Reprocesos y Doble Digitación

~6 Horas / Semana

Transcribir pedidos desde WhatsApp hacia Excel, imprimir a planta, pasar conteos manuales y volver a digitar facturas una a una en el portal DIAN.

Riesgo Sanitario ante Auditoría INVIMA

0% Trazabilidad Lote

El modelo de información AS-IS (Taller 2) carece de vínculo bidireccional entre el lote de rollo SMS recibido del proveedor y la remisión entregada a cada clínica.

Diagnóstico AS-IS: Shadow IT y Punto Único de Falla

ACTO 2 · ANÁLISIS

Hallazgos consolidados de Arquitectura C4 (Taller 3) y Topología de Infraestructura LAN / Planta (Taller 4)

Contenedores Actuales C1 / C2 (Taller 3): Shadow IT Crítico

Canales informales sin gobierno: El cierre comercial y envío de comprobantes opera sobre WhatsApp Business personal/oficina sin trazabilidad hacia facturación.

Ausencia de Servidor de Aplicaciones / BD: No existe motor relacional (PostgreSQL/ERP). La base de datos son 2 archivos Excel (.xlsx) compartidos por red Windows.

Aislamiento total de Planta: El área de confección (Zona Planta) no consume ningún sistema; recibe papel impreso y reporta consumos de palabra o planilla física.

Portal DIAN desconectado: Operación 100% manual vía navegador, obligando a digitar dos veces cliente, ítems y valores.

CONCLUSIÓN TÉCNICA C2:

El negocio creció a ~40 clínicas usando herramientas de oficina doméstica; cualquier escalamiento de pedidos multiplica errores y retrabajos.

Mapa de Infraestructura Actual (Taller 4): 3 Zonas con SPOF

Zona Nube Externa

Solo WhatsApp Web, Correo Gmail y Portal Gratuito DIAN.
Sin almacenamiento de negocio ni réplica externa automática.

Zona Oficina LAN — PUNTO ÚNICO DE FALLA (SPOF)

Router PyME ISP único + 3 PCs Windows en LAN.
1 disco duro local centraliza las carpetas SMB con los Excel.
Cero respaldos 3-2-1, cuentas genéricas compartidas y puertos USB abiertos.

Zona Planta de Confección

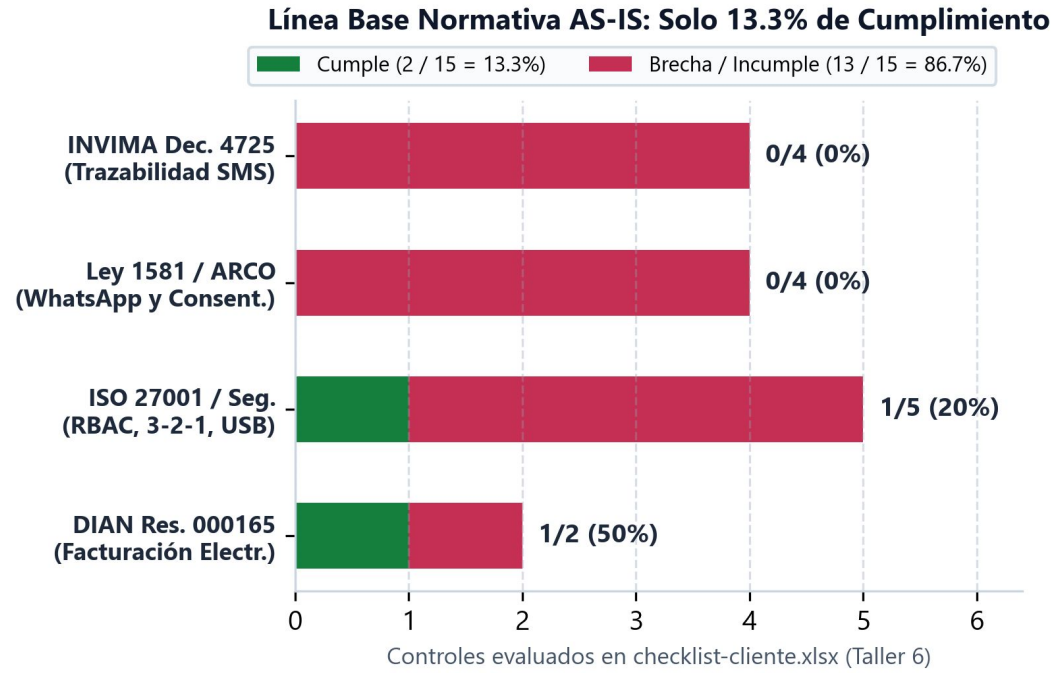
Estaciones de corte/confección sin cobertura Wi-Fi segura ni terminal web.
Dependencia absoluta del papel impreso para producir.

Riesgos de Seguridad (STRIDE) e Incumplimiento Normativo

ACTO 2 · ANÁLISIS

Exposición grave de activos y solo 13.3% de cumplimiento legal base (Evidencia: STRIDE Taller 5 & Checklist Taller 6)

Auditoría Normativa Base (checklist-cliente.xlsx · Taller 6)



Alerta Crítica (2/15 = 13.3%): Sin rastro de lote SMS (INVIMA Dec. 4725) y recolección de datos de clientes en WhatsApp sin autorización previa ni derechos ARCO (Ley 1581/2012).

Amenazas Críticas STRIDE en Flujo AS-IS (tabla-stride-cliente.xlsx · Taller 5)

T5 · Denegación de Servicio / Pérdida Total (Nivel Crítico)

Ransomware o fallo físico del único disco duro LAN sin backup externo 3-2-1 paraliza la operación y borra históricos.

T2 / T3 · Tampering y Repudio en Excels (Nivel Alto)

Cualquier empleado o tercero edita stock de SMS o precios sin bitácora inmutable (audit_log) ni responsable rastreable.

T1 · Spoofing por Cuentas Genéricas (Nivel Alto)

Sesiones de Windows compartidas sin usuario nominal impiden auditoría de accesos e incumplen ISO 27001 A.9.

T4 / T6 · Information Disclosure USB y SMB (Nivel Alto)

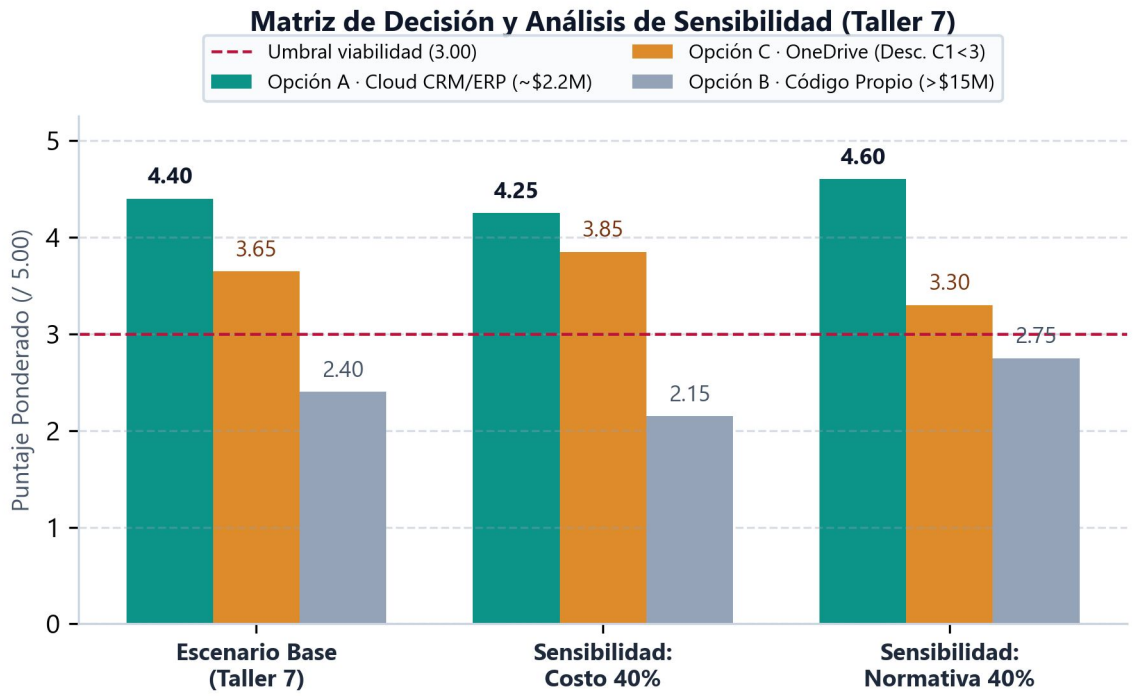
Puertos USB activos permiten extracción de bases de ~40 clínicas; carpetas SMB sin TLS/RBAC expuestas en red local.

Alternativa Seleccionada: CRM/ERP Cloud Ligero + Tablet Planta

ACTO 3 · SOLUCIÓN

Decisión sustentada por Matriz Ponderada y Análisis de Sensibilidad dentro del tope <= $3.0M COP/año (Taller 7)

Comparativa Multicriterio y Sensibilidad (informe.md · Taller 7)



Por qué se descartan B y C: Opción B (Código propio) excede 5x el presupuesto (>$15M/año); Opción C (Excel OneDrive) falla la restricción obligatoria C1 < 3 al no garantizar trazabilidad inmutable INVIMA.

Solución Aprobada (Opción A · Puntaje 4.40 / 5.00)

Núcleo CRM/ERP Cloud: Odoo Community / Dolibarr en nube administrada sobre PostgreSQL (~$2.2M COP/año; 27% debajo del tope).

Unificación Pedidos + Kardex: Al confirmar un pedido se valida y reserva rollo SMS al instante; cero bloqueos LAN.

Conector DIAN y Trazabilidad INVIMA: Exportador estructurado CSV/Excel para DIAN + campo obligatorio lote_sms_invima ligado a remisión PDF.

Seguridad Pragmática y Backup: HTTPS/TLS, RBAC con 6 usuarios nominales, audit_log en BD y respaldo diario 3-2-1.

TRADE-OFF EXPLÍCITO ACEPTADO (ADR #1):

Sacrificamos pantallas hechas 100% a medida y conexión API directa en tiempo real con DIAN a cambio de mantenernos <= $2.2M COP/año, reutilizar los PCs actuales y desplegar en 12 semanas sin código complejo que mantener.

Arquitectura Objetivo Integrada y Salto de Capacidades

ACTO 3 · SOLUCIÓN

Integración vertical en 5 capas cerrando los 10 GAPs del Taller 7 en 3 hilos E2E (Tablero Integrado · Taller 8)

Tablero Integrado TO-BE: 5 Capas y 3 Hilos E2E (Taller 8)

1. Negocio (OE-01..03)

Pedido único + orden digital sin papel + despacho certificado.

2. Información / Datos

BD PostgreSQL única (~40 clínicas, Lote SMS, audit_log inmutable).

3. Aplicaciones TO-BE

CRM/ERP Cloud + Tablet Web Planta + Exportador CSV DIAN.

4. Infraestructura

Cloud VPS/PaaS + PCs actuales + Tablet Wi-Fi WPA3 + Backup 3-2-1.

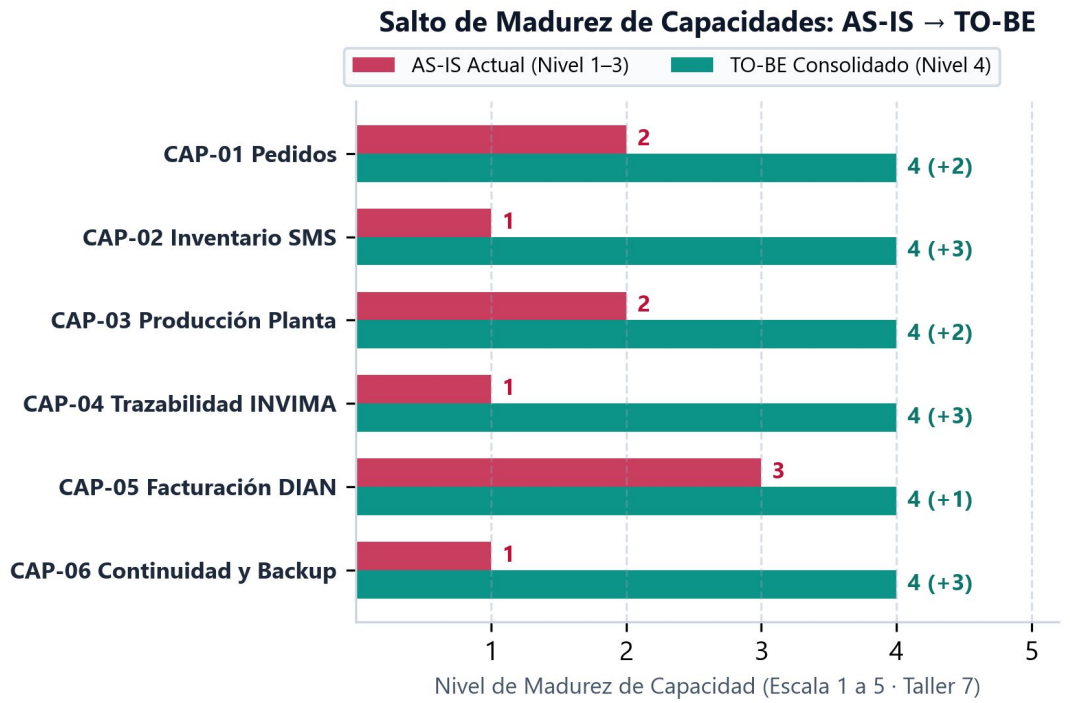
5. Seguridad / Legal

RBAC 6 cuentas, TLS, cierre SMB/USB, Ley 1581 y Dec. 4725 INVIMA.

3 HILOS E2E VERIFICADOS (TALLER 8):

- Hilo 1: Pedido WhatsApp (Ley 1581) → Reserva stock SMS en BD
- Hilo 2: Tablet Planta → lote_sms_invima → Remisión PDF clínica
- Hilo 3: Remisión cerrada → Exportador CSV DIAN sin redigitación

Evolución de Capacidades (CAP-01..06) y Brechas (GAP-01..10)



Cobertura total de brechas: Los 10 GAPs (GAP-01 a GAP-10) identificados en la matriz del Taller 7 quedan trazados 1-a-1 en los 4 Work Packages de la Vista de Migración ArchiMate.

Matriz Consolidada de Riesgos en los 7 Dominios (Bow-Tie)

ACTO 4 · PLAN Y RIESGOS

Consolida hallazgos de Talleres 4, 5 y 6 + Negocio, Datos y Procesos sin rehacer análisis previo (matriz-riesgos.xlsx)

ID	Riesgo Arquitectónico (Origen)	Dominio	Niv.	Estrategia	Control Bow-Tie	Fase Plan
R1	Silos Excel + bloqueos diarios LAN (T2/T3/T4)	Aplicaciones	**9**	Eliminar	Preventivo	WP2-B Mediano
R2	Alteración / repudio datos Excel sin logs (T5 STRIDE)	Seguridad	**9**	Reducir	Prev. + React.	WP2-B Mediano
R3	SPOF disco duro local / ransomware (T4/T5)	Infraestructura	**8**	Reducir	Reactivo (3-2-1)	WP1 Quick win
R4	Sin trazabilidad lotes SMS INVIMA Dec. 4725 (T6)	Gobierno TI	**8**	Eliminar	Preventivo	WP3 Largo
R5	WhatsApp sin aviso Ley 1581 / ARCO (T6)	Gobierno TI	6	Eliminar	Preventivo	WP1 Quick win
R6	Cuentas genéricas T1, SMB T6 y fuga USB T4 (T5)	Seguridad	6	Reducir	Preventivo	WP1 Quick win
R7	Órdenes papel en planta + redigitación DIAN (T1/T7)	Procesos	6	Reducir	Preventivo	WP2-B / WP3
R8	Maestros duplicados (~40 clínicas) y stock SMS (T2)	Datos	4	Reducir	Preventivo	WP2-A Corto
R9	Dependencia ISP PyME y equipo multifunción 6 pers.	Negocio	3	Transferir	Reactivo (SLA)	Gobernanza
R10	Fallo físico temporal de un PC sin espejo local (T0)	Infraestructura	2	**Aceptar ***	Reactivo	Gobernanza

CRITERIO BOW-TIE + SECUENCIACIÓN (PASO 3 Y 4):

Cada riesgo crítico combina prevención y contención reactiva. No ejecutamos primero R1/R2 (esfuerzo medio) sino R3/R5/R6 (Quick win en 2 sem) mientras preparamos la nube.

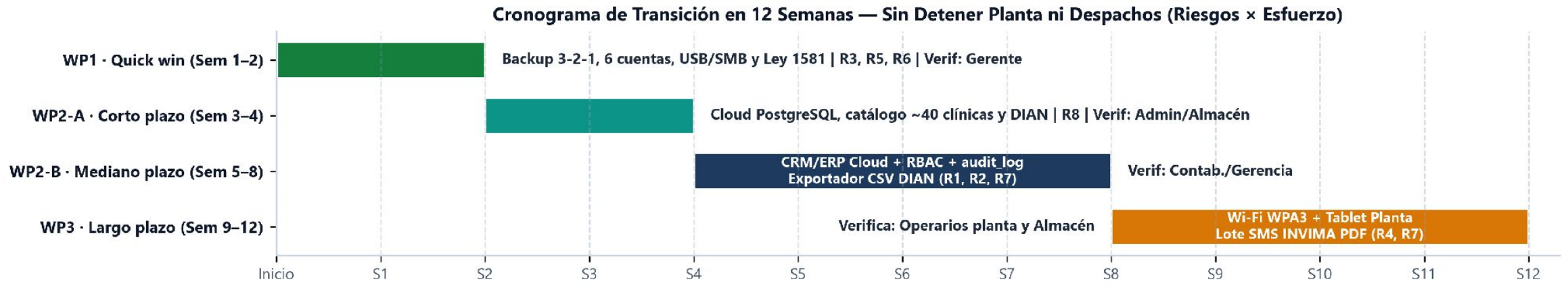
*** RIESGO R10 EXPLÍCITAMENTE ACEPTADO (NIVEL 2):**

No se compra PC espejo de reserva en bodega por restricción de presupuesto PyME (Taller 0). Desde WP2-B ningún dato vive en disco local: ante falla, cualquier equipo accede vía navegador.

Roadmap de 12 Semanas y Gestión del Cambio (Paso 4.1)

ACTO 4 · PLAN Y CAMBIO

Secuencia Riesgo × Esfuerzo en 4 fases (plan-implementacion.md) + adopción real con los 6 trabajadores



Gestión del Cambio con las Personas (Paso 4.1) — Capacitación 45–60 min y Marcha Blanca Paralela

Grupo Real (6 pers.)	Qué pierde o teme / Resistencia	Poder / Interés	Acción, Capacitación y Momento	Resultado Visible (Fuera de TI)
Operarios de confección (2 personas)	Temen vigilancia o trabas con Tablet; seguir pidiendo órdenes en papel.	Bajo / Alto	Práctica 45 min con lotes reales + 1 sem marcha blanca en Sem 9 (Líder Planta).	**WP3: Orden y lote SMS leídos en Tablet sin imprimir papel.**
Auxiliar Ventas / Admin (1 persona)	Miedo a que el ERP sea lento y reabra Excel paralelo 'por si acaso'.	Medio / Alto	Taller 60 min + 1 semana paralela en Sem 5; bloqueo de Excels antiguos.	**WP2-B: 0 bloqueos diarios y CSV DIAN exportado en <5 min.**
Encargado Almacén / Despacho (1–2 pers.)	Temor a quedar expuesto por descuadres previos de stock SMS.	Medio / Alto	Conteo conjunto sin sanciones antes de cargar inventario saneado en Sem 3–4.	**WP2-A / WP3: Remisión PDF emite el lote SMS automáticamente.**
Gerente / DPO PyME (Santiago Martínez)	Invertir > $3M/año sin ver orden ni control real de planta y cartera.	Alto / Alto	Tablero simple de cierre por fase (1 pág.) validando métricas M1–M3.	**WP1: Backup 3-2-1 probado y WhatsApp cumpliendo Ley 1581.**

Gobierno Ligero, Decisiones (ADR) y Métricas de Éxito

CIERRE · GOBERNANZA

Cómo se mantiene viva, segura y auditable la arquitectura después de la semana 12 (plan-gobernanza.md & procedimiento-cambios.md)

Principios y Comité Ligero

P1 · Sobriedad y Reúso: SaaS/Open-Source <= $3M/año y PCs actuales; prohíbe código a medida.

P2 · Fuente Única INVIMA: BD PostgreSQL única; prohíbe Excel paralelo y exige lote SMS.

P3 · Seguridad Pragmática: 6 usuarios nominales, RBAC, 3-2-1 y aviso Ley 1581 previo.

Retirado (Taller 0): Se retira el borrador de 'mantener Excels indefinidamente'.

COMITÉ Y CRITERIO TO-BE:

• 3 Roles: Gerencia (Santiago M.), Arquitecto Líder y Seguridad/Planta.
• Cadencia: Quincenal en transición (12 sem) y revisión total cada 6 meses.
• Escalado: Excepciones solo vía ADR en <= 5 días hábiles (<24h si urgente).

Registro Real: 2 ADRs y Cambios Futuros

ADR #1 · CRM/ERP Cloud PostgreSQL (Aprobada)

Adopta Odoo/Dolibarr Cloud (~$2.2M) y descarta dev propio (>$15M) y OneDrive. Se acepta perder UI a medida por rapidez, costos y cero bloqueos.

ADR #2 · Tablet Planta + CSV DIAN (Aprobada)

Tablet Wi-Fi WPA3 con lote obligatorio + exportador CSV DIAN (descarta API DIAN en F1 por costo y papel). Acepta carga de lote CSV hasta crecer volumen.

Disparadores de Cambio (Sec. 6.3):

Nueva regla INVIMA/DIAN, caída ISP/proveedor, incidente STRIDE o crecimiento +30% pedidos.

3 Métricas de Gobierno y Cierre

M1 · Adopción Fuente Única (P2)

Fórmula: Pedidos/movs en PostgreSQL ÷ totales × 100.
Base hoy: 0% (todo Excel) · Umbral alerta: < 80% Sem 8.

M2 · Cumplimiento Legal (P3)

Fórmula: Controles OK en checklist-cliente.xlsx ÷ 15 × 100.
Base hoy: 2/15 = 13.3% · Umbral: <60% Sem 4 / <90% Sem 12.

M3 · Agilidad del Comité (Gobierno)

Fórmula: Días hábiles entre Propuesta y Dictamen de ADR.
Base: Se mide desde ADR #1 real · Umbral estorbo: > 5 días.

IMPACTO FINAL PARA EL CLIENTE

· ~6 h/sem recuperadas · 0 bloqueos LAN
· Trazabilidad total lote SMS INVIMA PDF
· Costo ~$2.2M/año (<=$3M) · 0 paradas